

第一部分

1. 以下哪项是检查性控制？
 - A. 备份程序
 - B. 对输入数据执行程序化检查
 - C. 使用门禁卡访问机房
 - D. 哈希总计
2. 以下哪一项是降低未经授权访问无人值守的最终用户 PC 系统的最有效方法？
 - A. 强制使用密码保护型屏幕保护程序
 - B. 实施以邻近为基础的身份认证系统
 - C. 按预定义间隔终止用户会话
 - D. 调整电源管理设置，以保证显示屏是空白的
3. 问题管理的目的不是：
 - A. 迅速恢复事件
 - B. 降低事故发生的次数和严重性
 - C. 通过对重大事故进行调查和深入的分析后解决问题
 - D. 不断提高 IS 部门的服务质量
4. 某 IS 审计师正在审查某组织最新的灾难恢复计划（DRP）。确定该计划所需要的系统资源的可用性时，以下哪一项批准最重要？
 - A. 执行管理层
 - B. IT 管理层
 - C. 董事会
 - D. 督导委员会
5. 为防止在共享打印机上打印的保密文档泄露，应该采用以下哪种方法？
 - A. 加密用户计算机和打印机之间的数据流
 - B. 使用已打印文档的密级生成标题页
 - C. 要求授权用户在将文档发送到打印机之前提供密码
 - D. 在打印结果输出之前，要求现在打印机上输入密码
6. 为确保访问人力资源管理系统（HRMS）以及 HRMS 接口应用中的敏感数据的应用用户问责制，以下哪一项是应当实施的最有效的控制？
 - A. 双因素身份认证
 - B. 数字认证
 - C. 审计轨迹
 - D. 单点登陆身份认证

7. 以下哪种情况会增加欺诈行为的可能性？
- A. 应用程序开发人员正在执行对生产程序的变更。
 - B. 管理员正在对供应商提供的软件实施供应商补丁，但没有遵守变更控制流程。
 - C. 操作支持人员正在执行对批量计划的变更。
 - D. 数据库管理员正在执行对数据结构的变更。
8. 某企业发现重大数据安全漏洞，CEO 要求详细审计网络安全，但由于近期人员重组，审计部门只有几位经验欠缺的审计师，信息系统审计经理应该：
- A. 请外部组织审计；
 - B. 下一年度将发现次问题列为重点；
 - C. 派资深的信息系统审计师完成审计任务；
 - D. 推迟审计，完成审计必须的信息安全知识培训工作后再审计
9. 项目上线后的审查中，应审查以下哪一项来确定项目是否满足用户要求？
- A. 用户文档的完整性
 - B. 并行测试的结果
 - C. 程序更改请求的类型。
 - D. 关键计算的完整性
10. 以下哪项使用回归测试：
- A. 单元测试
 - B. 系统修改
 - C. 程序开发
 - D. 压力测试
11. IT 项目管理中，优先图示法(procedence diagramming Method)的特点是
- A、减少项目的延误和超出预算
 - B、关键里程碑
 - C、关键路径
 - D、监控项目范围变化
12. 以下哪一项是表明高级管理层审查了 IT 表现的最佳证据？
- A. 执行管理委员会会议纪要
 - B. IT 战术规划
 - C. 平衡积分卡
 - D. 关键性 IT 表现指标
13. 信息系统审计师在审查某应用程序是否符合信息隐私保护原则时，应该最关注以下哪项？
- A. 完整性
 - B. 不可抵赖性
 - C. 可用性
 - D. 信息收集限制

14. 软件成熟度模型的最高级别是:

- A. 成熟的项目管理
- B. 项目管理是“混乱的”，管理人员的精力都用于“救火”
- C. 持续改进监控
- D. 质量过程的有效管理与度量

15. 从 IT 治理的角度来说，董事会的主要职责是什么？确保 IT 战略：

- A. 具有成本效益。
- B. 面向未来和具有创新性。
- C. 与业务战略相一致。
- D. 分配有适当的优先级。

16. 信息系统审计师已经完成了外包协议的审查工作，并确定了 IT 治理问题，下面哪项是管理层会议上交流这些问题的最有效方法？

- A. 提供概述，并突出显示关键调查结果
- B. 预先提供详细报告，并回答大家的提问
- C. 提供完成的报告并讨论详细情况
- D. 提供更改计划和里程碑

17. 在下列哪个过程中会使用到 Hash:

- A. 对称加密
- B. 数字签名
- C. 非对称加密
- D. PKI

18. 以下哪一项能最有效地确保会计系统内部利息计算相关控制的有效性？

- A. 重新执行
- B. 流程穿行测试
- C. 观察
- D. 文档审查

19. 数据库管理员发现一些表的性能问题可以通过反向规格化（denormalization）来解决。这种情况下会增加哪像风险（）？

- A. 同时并行访问
- B. 死锁
- C. 非授权的数据访问
- D. 数据完整性的丢失

20. 下列哪项是电子交易系统最大的风险？

- A. 未启动交易轨迹

B. 未作路由校验

C. 密码没有加密

D. 未验证客户身份即进入交易接口

21. 一家拥有 300 家零售店铺的公司正在部署分布式新系统，下面哪一种上线计划比较合适？

A、在某个典型店铺实施上线

B、300 家店铺全部并行上线

C、挑选一些具有特点的店铺并行上线

D、分阶段上线

22. 信息系统审计师将发现的问题报告给审计方，审计方管理层忽视该问题的存在，第三方组织需要获取审计报告，此时信息系统审计师应：

A. 获取被审计组织的认可后，提供给第三方

B. 获取组织审计管理层的认可后，提供给第三方

C. 获取审计委员会认可后提供给第三方

D. 获取被审计组织和组织的审计管理层许可后，提供给第三方

23. 某 IS 审计师正在审计某 IT 灾难恢复计划(DRP)。该 IS 审计师应当主要确保该计划涵盖：

A.恢复能力强的 IT 基础设施

B.备用站点信息。

C.记录在案的灾难恢复 (DR)测试结果。

D.业务功能的分析与优先级分配。

24. 在审查互联网和防火墙规则时，信息系统审核师最担心的是？

A. 用户可以访问安全套接层 (SSL)

B. 用户通过 MODEM 来访问互联网

C. IP 地址允许使用授权的传输控制协议 (TCP) 服务。

D. 防火墙规则未检测到所检索的网页

25. 生物访问控制的错误拒绝率最高

A.虹膜识别

B.指纹

C.面部识别

D.视网膜识别

26. 某供应商过去几个月发布了多个重要的安全修补程序，因此对管理员及时测试和部署修补程序的能力带来压力。管理员已询问能否减少对修补程序的测试。该组织应当采取哪种措施？

A. 继续坚持当前测试和应用修补程序的流程。

B. 减少测试并确保制订充分的逆向恢复计划。

C. 推迟安装修补程序，直到测试资源可用。

D. 依靠供应商测试修补程序。

27. 在 IS 审计过程中, IS 审计师评估 IT 部门内部职责分工落实情况的最佳方法是什么?

- A. 与 IT 经理开展讨论。
- B. 审查 IT 职能部门的工作说明。
- C. 搜索过去的 IS 审计报告。
- D. 评估组织架构。

28. 审查来自供应商的服务级别报告能最有效地协助审计师确定?

- A. 供应商是否提供了必要的安全保障
- B. 供应商是否遵循所有的适用的法律法规
- C. 与供应商合同到期后是否可以续约
- D. 供应商是否在实现预期目标

29. IS 审计师发现被审计的企业, 各部门均制订了充分的业务连续性计划 (BCP), 但是没有整个企业的 BCP。那么, IS 审计师应该采取的最佳行动是:

- A. 建议增加、制订全企业的、综合的 BCP
- B. 建议合并所有 BCP 为一个单独的全企业的 BCP
- C. 确定各部门的 BCP 是否一致, 没有冲突
- D. 各业务部门都有适当的 BCP 就够了, 无需其它

30. 评估为新会计应用进行采购的业务案例时, 以下哪一项考虑因素最重要?

- A. 应用的总拥有成本 (TCO)
- B. 实施应用所需要的资源
- C. 对公司的投资回报率 (ROI)
- D. 安全需求的成本和复杂度

31. 以下哪一项措施最能够确保输入到税款计算机程序中的固定税率的准确确定?

- A. 数据输入范围的程序化合理性检查
- B. 用来防止无数数据输入的程序化编辑检查
- C. 对输入的数据进行目视检查
- D. 用户独立审核测试结果

32. 一个公司正在实施控制自我评估项目, 审计师应该作什么:

- A. 跟踪项目的执行情况, 并及时报告进展状况。
- B. 以领导者的身份参加项目。
- C. 项目审批者。
- D. 审计师应该重新修订审计方案, 以避免与自我评估的内容重复

33. 在 IT 治理中, 以下哪一项对有效的风险管理来说事必要的?

- A. IT 风险管理与公司风险管理相分离
- B. 审计委员会负责批准风险管理策略
- C. 各地区经理 (local managers) 只负责风险评估
- D. 在管理过程中对风险进行评估

34. 信息系统审计师审查各种IT外包合同采购流程。确保中标的承包商满足以下哪项要求？

- A. 维护了内部审计功能。
- B. 是按确定的业务标准选择出来的。
- C. 要求所有员工都签署机密性协议。
- D. 消除了外包风险。

35. 组织使用生产系统的交易信息，最大的风险是：

- A. 对信息未进行脱敏处理
- B. 对生产系统的交易信息修改进行测试
- C. 不能测试全部功能
- D. 交易信息中有大量相似数据

36. 某公司确定其网站遭到损坏，在托管应用的服务器上被安装了 rootkit 恶意软件。以下哪一项最有可能防止事故？

- A. 基于主机的入侵防御系统（IPS）
- B. 基于网络的入侵检测系统（IDS）
- C. 防火墙
- D. 安装操作系统（OS）修补程序 A

37. 信息系统审计师发现，为了提高性能已经WEB应用程序的验证控制从服务器迁移到客户端，那么遭受以下哪一项攻击的风险最可能增加？

- A. PHISHING
- B. SQL 注入
- C. DOS
- D. 缓冲区溢出

38. 检查点是在以下哪项之后应用的

- A. 增量数据备份
- B. 数据中心停电
- C. 执行了不正确的程序版本
- D. 出现临时硬件故障

39. 在审查数据中心运行的有效性时，信息系统审计师需首先确定系统性能，用于以下哪项工作？

- A. 按照事先约定的服务等级进行监控和报告
- B. 满足制造商规定的预期目标
- C. 在该系统的公认可靠性等级之内
- D. 能够反映在实施时确立的预期使用水平

40. 当开发一个业务连续性计划时，应该用下列哪种形式来获得对组织业务流程的理解？

- A. 风险评估
- B. 差距分析
- C. 业务连续性自我审计

D. 资源恢复分析

41. 正在对开始开发的某应用执行风险评估。在建议安全控制之前，需要确定的最重要的内容是什么？

- A. 基于角色的访问控制(RBAC)
- B. 当前的隐私权法律
- C. 数据分类
- D. 数据托管位置

42. 下列哪一种访问控制组合能为服务器机房提供双因素保护？

- A. 用户 ID 和 PIN
- B. PIN 和智能卡
- C. 磁卡和智能卡
- D. 磁卡和共享 PIN

43. 以下哪一项能最有效地控制数字订单号输入的准确性？

- A. 哈希总计
- B. 数字有效性检查
- C. 与历史订货模式比较
- D. 联机检查描述

44. 公司将进行信息系统职能外包，为满足灾难恢复的需要，该公司应该：

- A. 将灾难恢复的评估工作委托给内部审计部门
- B. 将灾难恢复的评估工作委托给第三方
- C. 进行灾难恢复计划维护工作
- D. 与外包供应商协调恢复管理措施

45. 下面哪一项是最佳的数据完整性检查？

- A. 将数据追溯至源点
- B. 计算每天处理的交易量
- C. 准备和运行测试数据
- D. 执行连续性检查

46. 当某公司按照合同实施新软件时，下面哪种方法对于控制因范围蔓延导致成本增加是至关重要的？

- A. 质量管理
- B. 问题管理
- C. 风险管理
- D. 变更管理

47. 以下哪种报告最能够有效分析系统的性能？

- A. 控制台日志
- B. 同步报告
- C. 数据库使用日志

D. 使用情况报告

48. 审计师发现开发项目的范围被显著缩减，下列哪一项是审计师此时应采取的最重要行动？

- A. 确认相关部门和管理层范围缩小的事实
- B. 确认 IT 成本是否已降低
- C. 是否已经采用了管理成熟度等级
- D. 是否对关键控制的影响

49. 下面哪一项措施是防止非授权登录最可靠的方法？

- A. 加强现有的安全策略
- B. 发放身份令牌
- C. 限制在下班后使用计算机
- D. 安全自动密码生成器

50. 以下哪一项是进行业务影响分析的第一步？

- A. 确定影响运行连续性的事件
- B. 创建数据分类方案
- C. 分析过去的交易量
- D. 确定关键信息资源

51. 对于 VoIP，信息系统审计师最关注什么？

- A. 不可抵赖性
- B. 服务的连续性
- C. 网络的统一性
- D. 数据与语音网络分离

52. 某 IS 审计师正在评估某组织新制订的一项 rr 政策。该 IS 审计师认为以下哪一项因素对促进政策实施后的合规性最重要？

- A. 促成合规性的现有 IT 机制
- B. 政策与业务战略相一致
- C. 当前和将来的技术措施
- D. 政策中定义的监管合规性目标

53. 信息系统审计师在审查桌面软件配置文件时注意到，一个用户已下载并安装了公司不批准的游戏。以下哪一项是这一状况可能产生的最大风险？

- A. 潜在的恶意软件
- B. 未遵守可接受使用政策
- C. 与公司软件的互操作性问题
- D. 违反用户的隐私

54. 使用 RSA 加密法创建的数字签名所提供的控制，最有可能受到下面哪种攻击？

- A. 通过摘要来反推哈希函数
- B. 泄露的私钥

C. 泄露的摘要

D. 泄露的公钥

55. 下列哪项最能表明安全角色和责任在整个企业都得到有效落实?

A. 业务活动符合策略的规定

B. 用户签署了保密协议

C. 安全策略的出台和发布

D. 定期审查病毒更新策略

56. 在审查质量管理体系 (QMS) 时, IS 审计师应当主要注重收集证据, 以表明:

A. 质量管理体系 (QMS) 遵循良好实践。

B. 正在监测持续改进目标。

C. 每年更新 IT 标准操作程序。

D. 定义了关键绩效指标(KPI)。

57. 如下哪个是进行业务影响分析的最好方法?

A. 对主要业务相关者发布调查问卷

B. 和主要业务相关者进行面谈

C. 与 IT 管理人员进行面谈

D. 咨询相关专家

58. 某 IS 审计师已发现, 员工们在通过电子邮件将敏感的公司信息发送到基于 web 的公共电子邮件域。对 IS 审计师而言, 以下哪一项是建议的最佳补救措施?

A. 加密邮件帐户

B. 培训和意识

C. 活动监测

D. 数据丢失防护 (DLP)

59. 根据信用卡刷卡时间, 地点, 金额等信息, 以下那种审计分析方法可以发现一家银行的信用卡用户使用的潜在风险?

A. 日志分析法

B. 趋势分析法

C. 属性分析法

D. 预测性数据挖掘

60. 对于抽样而言, 以下哪项是正确的?

A. 抽样一般运用于与不成文或无形的控制相关联的总体

B. 通过尽早停止审计测试, 属性抽样有助于减少对某个属性的过量抽样

C. 变量抽样是估计给定控制或相关控制集合发生率的技术

D. 如果内部控制健全, 置信系数可以取的较低

61. 发现网站服务停止响应, 很多用户报告说连不上系统, 最有可能遭到什么攻击?

A. 恶意代码

B. 中间人

- C. 中断攻击
- D. DOS

62. 某 IS 审计师在对新安装的互联网语音协议(VoIP)系统进行审计时，检查了每层楼的配线柜。以下哪一项最令人担心？

- A. 局域网 (LAN)交换机未连接不断电源(UPS)单元。
- B. 网络布线杂乱，并且未适当粘贴标签。
- C. 电话和 LAN 连接使用相同的电缆。
- D. 配线柜中还包含电源线和断路器面板。

63. 如何有效在网络环境防止蠕虫？

- A. 接种疫苗
- B. 防毒软件
- C. 减少网络节点
- D. 防火墙

64. 一家公司采用轮班作业，以下那种授权策略应该被采用：

- A. 强制控制授权
- B. 自主控制授权
- C. 基于规则的授权
- D. 基于角色的授权

65. 测试 BCP 的主要原因在于确保：

- A. 能够恢复关键数据。
- B. 熟悉恢复程序，尽可能减少实际实施中的紧张情绪。
- C. 树立自身灾难期间的信心。
- D. 确保灾难恢复小组成员得到培训。

66. 防尾随的物理安全控制，对于无双门设置的数据中心，以下哪项是最好的措施

- A. 双因素认证
- B. 生物识别
- C. 安全教育
- D. 口令

67. IS 审计师被 IS 管理人员告知，组织最近已达到软件能力成熟度模型(CMM)的最高级别。则该组织最近添加的软件质量过程为：

- A. 持续改进。
- B. 定量质量目标。
- C. 记录流程。
- D. 为特定项目制定的流程。

68. 在审计过程中，IS 审计师发现，人力资源(HR)部门用云应用来管理员工记录。HR 部门越过正常的供应商管理流程参与一份合同，并自行管理应用。以下哪一项最值得关注？

- A. 未在合同中定义最长的可接受停机时间指标。

- B.IT 部门不管理与云供应商之间的关系。
- C.服务台呼叫中心驻在不同的国家，需遵守不同的隐私要求。
- D.公司定义的安全政策不适用于云应用。

69. 机密数据从盒式磁带备份运用到基于云的解决方案最大顾虑

- A.未买网络保险
- B.用手实施的人员不足
- C.情理部门企图并行使用盒式磁带系统
- D.缺少对传输到云的方案加密流程

70. 数字签名最可能阻止

- A.未授权更改
- B.抵赖行为
- C.泄露
- D.数据损坏

71. 某 IS 审计师已发现有了某应用的新修补程序，但 IT 部门已决定不需要该修补程序，原因是落实了其他安全控制措施。该 IS 审计师应该建议以下哪个选项？

- A.在可以对其进行测试后，无论如何都要应用该修补程序。
- B.实施基于主机的入侵检测系统（IDS）。
- C.实施防火墙规则，以进一步保护应用服务器。
- D.评估整体风险，然后决定是否部署修补程序。

72. 软件质量保证（QA）审查工作被作为系统开发过程的一个环节纳入了计划。这项工作处于开发过程的哪个阶段？

- A. 可行性研究过程中
- B. 用户验收测试之前
- C. 实施前的计划时
- D. 定义用户需求时

73. 数据库重组的目的是？

- A. 缩短同时更新时间和索引验证
- B. 减少反问恢复和恢复次数
- C. 消除重复内容并进行数据备份
- D. 改进数据访问和检索次数

74. 信息系统审计师格外关注互联网环境中的缓冲区溢出的问题，因为这可能导致：

- A. 破坏数据库
- B. 获得对某系统的非法访问权
- C. 打印时丢失某些文档内容
- D. 丢失关键数据

75. IS 审计师发现企业的业务连续性计划中选定的备用处理设施的处理能力只能达到现有系统的一半。那么，他/她该怎么做？

- A. 无需做什么。因为只有处理能力低于正常的 25%，才会严重影响企业的生存和备份能力
- B. 建议相关部门增加备用设施投入，使其能够处理 75%的正常业务
- C. 找出所有主要的应用，确保备用设施可以运行这些应用
- D. 找出可以在备用设施使用的应用，其它业务处理采用手工操作，制订手工流程以备不测

76. 要实施 IT 治理框架，董事会需要做到？

- A. 解决 IT 技术问题
- B. 成立 IT 战略委员会
- C. 审计 IT 战略
- D. 了解所有 IT 项目发展

77. 某 IS 审计师正在审查已采纳敏捷开发方法的某组织的软件开发能力。该 IS 审计师最关注的是：

- A.某些项目迭代产生包括概念验证的交付成果和未完成代码。
- B.应用特征和开发过程未广泛记录在案。
- C.软件开发团队不断重新规划其重大项目的每一步。
- D.项目经理不管理其项目资源，而将其交由项目团队成员负责。

78. 某 IS 审计师在数据库的某些表中发现了超出范围的数据。为避免此类状况发生，该 IS 审计师应推荐采用以下哪种控制？

- A.记录所有的表更新交易。
- B.在数据库中设定完整性约束。
- C.使用前后图像报告。
- D.使用跟踪和标记。

79. 某 IS 审计师正在对某数据中心的灾难恢复（DR）程序进行审查。表明该程序符合要求的最佳指标是以下哪一项？

- A.记录在案的程序经过管理层批准。
- B.程序经过审查，并与行业良好实践进行过比较。
- C.用该程序进行过桌面演练。
- D.恢复团队及其职责已记录在案。

80. 应在软件开发的哪个阶段制定用户验收测试计划？

- A. 需求定义时
- B. 投入使用时
- C. 可行性研究时
- D. 系统实施规划阶段

81. 信息系统审计师发现组织存在一个漏洞，信息系统审计师应该？

- A. 要求尽快修复此项漏洞
- B. 通知业务方
- C. 调查漏洞引发威胁的概率
- D. 记入审计报告

82. 在拟定基于风险的审计计划时，以下哪一项是最好的信息来源？

- A. 流程所有者识别关键控制。
- B. 系统监管人识别漏洞。
- C. 审计团队成员了解以前的审计结果。
- D. 高级管理层识别关键业务流程。

83. 为支持一百多个终端使用的服务器选型时，最应考虑下列哪一项？

- A. 各个系统的高可用性
- B. 厂商的声誉及客户群
- C. 比较可用的各个系统的成本效益。
- D. 高峰期的预计交易量

84. 要求督导委员会监督 IT 投资的主要好处是以下哪一项？

- A. 进行可行性分析，以表明 IT 价值
- B. 确保根据业务需求进行投资
- C. 确保强制落实适当的安全控制措施
- D. 确保实施标准的开发方法

85. 吞吐量索引表明：

- A. 系统资源处于繁忙状态时间比例
- B. 系统为用户提供输出速度多快
- C. 系统在一段时间内完成的工作量
- D. 用来处理用户工作的系统资源

86. 下哪一项最有可能确保灾难恢复 (DR) 工作取得成功？

- A. 进行桌面演练。
- B. 完成数据恢复。
- C. 批准恢复程序。
- D. 承诺适当的人力资源。

87. 在应用程序软件审查过程中，某 IS 审计师在超出审计范围的相关数据库环境中发现了细小的漏洞。最佳选项是：

- A. 包括审查范围内的数据库控制。
- B. 记录下来供日后审查。
- C. 与数据库管理员共同解决问题。
- D. 如实报告漏洞。

88. 一家小公司要购买服务器用于订单处理系统，但无法预计交易量，以下哪一项是公司最关注的？

- A. 系统的可扩展性
- B. 系统的配置参数
- C. 系统优化
- D. 系统的兼容性

89. 在下列哪一个 SDLC 阶段，信息系统审计师应该会发现控制措施已集成到系统规范中？

- A. 可行性研究阶段
- B. 实施阶段
- C. 设计阶段
- D. 开发阶段

90. 某批量交易作业在生产中操作失败；但在用户验收测试（UAT）中，同一作业却未出现问题。生产批量作业分析显示，它在 UAT 后经过修改。将来减小这种风险的最佳途径是以下哪一项？

- A. 完善回归测试案例。
- B. 针对发布后的有限时间段启用审计轨迹。
- C. 执行应用用户访问审查。
- D. 确保开发人员在测试后无访问权限进行编码。

91. 以下哪一项在电子邮件中保护消息的机密性：

- A. 加密
- B. SHA-1
- C. 数字签名
- D. 数字证书

92. 在审查 IT 项目与项目管理的优先次序和协调事宜时，对 IS 审计师而言，主要考虑因素是什么？

- A. 项目与组织战略相一致。
- B. 识别的项目风险得到监控和缓解。
- C. 与项目规划和预算编制相关的控制措施是适当的。
- D. 准确报告 IT 项目指标。

93. 下列哪一项能够最有效地保护数据中心的信息资产不被供应商窃取？

- A. 监控并限制供应商的活动
- B. 限制使用便携式和无线设备
- C. 隐藏数据设备和信息标签
- D. 给供应商发放门禁卡

94. 说明电子商务发展的业务案例

- A. 缩短生产商品的时间
- B. 通过联机订单收费增加收入
- C. 提高公司竞争力
- D. 降低未授权而访问数据库风险

95. 中央防病毒系统负责在允许个人电脑接入网络之前，确定每台 PC 机是否具有最新的病毒定义文件，并安装最新的病毒定义文件。

- A. 指令性控制。
- B. 改正性控制。
- C. 补偿性控制。

D.检测性控制。

96. 在确定信息资产的适当保护等级时，IS 审计师应当主要关注以下哪一个因素？

- A.风险评估的结果
- B.对业务的相对价值
- C.漏洞评估的结果
- D.安全控制的成本

97. 哪种有助于确保批文件转移的完整性

- A.散列总计
- B.自检数字
- C.奇偶校验
- D.输入控制

98. IS 审计师在审计电子商务环境时，最重要的是要理解以下哪一项？

- A.电子商务环境的技术架构
- B.构成内部控制环境的政策、程序和实务
- C.应用系统所支持的业务流程的性质和重要性
- D.系统可用性和可靠性控制措施的持续监测

99. 某 IS 审计师正在为某大型跨国公司审查应用变更管理流程，他最担心发生以下哪种情况？

- A.测试系统的运行配置与生产系统不一样。
- B.变更管理记录为纸质记录
- C.配置管理数据库未经维护
- D.测试环境安装在生产服务器上

100. 项目发生变化，但对应的业务案例没有变化，最大的风险是：

- A. 影响业务实施
- B. 影响 IT 实施
- C. 超出预算
- D. 没有人支持项目

第二部分

1. 哪种方式保证 Email 系统传输的机密性？
 - A. 加密
 - B. 数字认证
 - C. 数字签名
 - D. 将服务器放在本地
2. 在多个地点实施新管理系统，新系统有 4 个集成模块，下列哪种实施方法最好
 - A. 试运行系统
 - B. 完全实施新系统
 - C. 所有地点并行运行
 - D. 逐个模块并行实施
3. 下面哪一项能够最有效地确保只有适当的用户才能进行薪资处理？
 - A. 使用网络安全软件，来限制对处理的访问
 - B. 对敏感的应用程序交易，使用一个独立的菜单
 - C. 由主管负责批准薪资处理
 - D. 将访问权限限制在应用程序级别
4. 某 IS 审计师正在对某组织的系统进行实施后审查，并发现了会计应用内部的输出错误。该 IS 审计师确定这是由输入错误造成的。该 IS 审计师应当向管理层建议以下哪一项控制？
 - A. 重新计算
 - B. 极限检查
 - C. 运行到运行的汇总
 - D. 对账
5. 在审查 IT 资源能力和性能的持续监测流程时，IS 审计师应当主要确保该流程重点关注：
 - A. 充分监测 IT 资源和服务的服务等级。
 - B. 提供数据，以确保能够及时规划容量和性能要求。
 - C. 提供有关 IT 资源可用性的准确反馈。
 - D. 正确预测 IT 资源的性能、能力和吞吐量。
6. IT 风险评估应包括识别以下哪项？
 - A. 补偿控制措施
 - B. 弱点
 - C. 业务流程所有者
 - D. 业务要求

7. 下列哪一种灭火系统需要与自动开关组合，才能在警报激活时切断电源？
- A. 二氧化碳
 - B. 七氟丙烷
 - C. 灭火卤化物
 - D. 干管灭火
8. 使电子商务应用程序更强壮的最佳方法：
- A. 集群服务器
 - B. 磁盘冗余阵列 0(RAID0)
 - C. 电子保险箱
 - D. 外部设备
9. 在灾难恢复审计过程中，某信息系统审计师发现没有进行业务影响分析，审计师需首先开展哪项工作？
- A. 执行额外的符合性测试
 - B. 评估对当前灾难恢复能力的影响
 - C. 执行业务影响分析
 - D. 向管理层提交报告
10. 多个远程用户无法与安全的 NTTP 服务器通信，最可能的原因是：
- A. 黑客模拟了此服务器
 - B. 使用密码破解软件
 - C. 偷听者重播攻击
 - D. 黑客使用探查器
11. 在对最近部署的应用执行实施审查过程中，发现几个事故被分配了错误的优先级，并因此未能符合服务等级协议（SLA）的要求。以下哪一项最令人担心？
- A. 支持模型未经高级管理层批准。
 - B. SLA 中规定的事事故解决时间不现实。
 - C. 没有足够的资源来支持应用。
 - D. 未适当开发和实施支持模型。
12. 下列哪一项能够最有效地防止病毒进入局域网中
- A. 禁止用户访问互联网
 - B. 定期扫描网络上的硬盘
 - C. 禁用下载可执行文件的能力
 - D. 在网络服务器上安装内存驻留病毒扫描程序
13. 怀疑一个用来处理数据的 PC，被用于针对财务部门的舞弊，应首先向谁报告
- A. 业务管理部门
 - B. 警察
 - C. 审计委员会
 - D. 审计管理部门

14. IS 审计师需验证应用发布后是否有完成实施后审查流程的主要原因是什么？
- A. 确保用户经过适当培训
 - B. 验证项目在预算范围之内
 - C. 核实项目达到预期
 - D. 确定是否已实施适当的控制措施
15. 在开发整个公司电子数据交换（EDI）项目的过程中，必须完成下列那一项？
- A. 实施消息标准
 - B. 审查所有供应商的 EDI 应用程序
 - C. 实施加密技术
 - D. 安装一个 ISDN
16. 制订业务连续性计划的第一步，也是必不可少的一步是：
- A. 软件和硬件的可用性
 - B. 罗列出所有资产的清单
 - C. 完整地记录所有灾难
 - D. 根据风险将应用系统分类
17. 在审查计算机处置流程时，IS 审计师最担心以下哪项？
- A. 硬盘在扇区级别进行了多次覆写，但在送出组织前没有重新格式化。
 - B. 分别删除硬盘上的所有文件及文件夹，并在送出组织前格式化硬盘。
 - C. 送出组织前在盘片的几个指定位置打孔，使硬盘变得不可读。
 - D. 由内部安全人员将硬盘护送到附近的金属回收公司，在此处注册并随即粉碎硬盘。
18. 了解一个操作系统的安全配置的最佳方式是：
- A. 学习供应商的安装手册。
 - B. 检查系统安全计划。
 - C. 跟安装软件的系统程序员面谈。
 - D. 查看系统自动配置的参数。
19. 在对数据中心进行审计时，审计师应当检查电压调整器是否存在，以保证：
- A. 如果主电力被中断，可以提供实时的电力供应
 - B. 保护硬设备不受长期电力波动的影响
 - C. 保护硬设备免受浪涌损害
 - D. 如果主电力被中断，系统的完整性也可以得到维护
20. 对于数据外包的第三方外包供应商发生数据泄露事件首先应
- A. 启动灾难恢复计划
 - B. 就损坏声誉对服务商采取法律行动
 - C. 启动事故管理
 - D. 保险公司索赔
21. 审计目标应如何决定？
- A. 董事会决议

B. 公司政策

C. 重要的业务流程

D. 风险分析

22. 银行的自动柜员机 (ATM) 是一种专门用于销售点的终端, 它可以:

- A. 必须包括高层的逻辑和物理安全
- B. 一般放置在入口稠密的场所以威慑盗窃与破坏
- C. 只能用于支付现金和存款服务
- D. 利用保护的通讯线进行数据传输

23. 在 EFT 系统实施时, 审计师最关注?

- A. 项目是否满足了业务目标
- B. 用户是否积极参与系统的获取过程
- C. 系统供应商的资质
- D. 通信线路的加密

24. 对 IS 审计师而言, 如果下列用户组具有生产数据库的直接完全访问权限, 以下哪一组最值得关注?

- A. 应用测试员
- B. 系统管理员
- C. 数据库所有者
- D. 数据恢复团队

25. 审查数据中心环境控制中的灭火系统时, 应考虑

- A. 维护措施
- B. 安装手册
- C. 是否能现场安装
- D. 承保范围

26. 某卫生保健组织的 IS 审计师正在检讨考虑由其托管患者健康信息 (PHI) 的第三方云提供商的合同条款和条件。以下哪一项合同条款将成为客户组织面临的重大风险?

- A. 数据所有权归属客户组织。
- B. 第三方保留访问数据以执行某些操作的权利。
- C. 未定义批量数据撤回机制。
- D. 客户组织负责备份、归档和恢复。

27. 审计新应用系统的持续运行计划的最佳时间是?

- A. 交接给系统维护部门之前
- B. 上线后立即进行
- C. 系统需求阶段
- D. 成功进行用户测试之后

28. 某组织实施了一个分布式会计系统, IS 审计师正在进行实施后审查, 以提供数据完整性

控制的鉴证。该审计师应当首先执行以下哪一项？

- A. 审查用户访问。
- B. 评估变更请求流程。
- C. 评估对账控制。
- D. 审查数据流程图。

29. 在对医疗组织的受保护医疗信息(PHI)进行 IS 风险评估时,IS 审计师在与 IS 管理人员面谈。此次面谈中的哪项发现最令 IS 审计师关注？

- A. 组织没有对所有外发的电子邮件进行加密。
- B. 员工必须在电子邮件的主题栏键入 “[PHI]” 才能进行加密。
- C. 个别工作人员的计算机屏保功能被禁用。
- D. 服务器配置要求用户每年更改一次密码。

30. 在实施数据分类程序时，以下哪一项最重要？

- A. 实施数据标准化
- B. 理解数据的业务用途
- C. 计划安全存储容量
- D. 开发隐私策略

31. 某 IS 审计师正在审查某组织的网络操作中心（NOC）。以下哪一项最受关注？采用：

- A. 基于湿管的灭火系统。
- B. 租借的 NOC 机架空间。
- C. 基于二氧化碳的灭火系统。
- D. 备用电力为 10 分钟的不间断电源（UPS）。

32. A 公司计划实施的系统所采用的技术不符合公司 IT 策略。以下哪一项是最佳理由？

- A. 虽然导致成本增加，但可以增加企业效益
- B. 员工非常熟悉此技术
- C. 该系统采用最先进的技术
- D. 该系统的持有成本较低

33. IS 审计师检查企业的生产环境中的主机和客户/服务器体系之后。发现的哪一种漏洞或威胁需要特别关注？

- A. 大多数局域网上的服务器没有执行定期地硬盘备份
- B. 安全官兼职数据库管理员
- C. 主机系统上运行的非关键应用没有纳入业务持续性计划的考虑
- D. 客户/服务器系统没有适当的管理口令/密码控制

34. 在项目的问题（issues）管理过程中，将出现下面哪类工作？

- A. 配置管理
- B. 突发事件处理计划
- C. 客户服务管理
- D. 影响评估

35. 下列哪一项是用户部门与程序变更相关的最重要的职责
- A. 更新文档，以体现出最新的变更
 - B. 提供单元测试数据
 - C. 分析变更需求
 - D. 实施之前批准变更
36. 紧急情况下关闭电源的开关应该：
- A. 受保护
 - B. 不在计算机机房中
 - C. 无识别标记
 - D. 会发亮
37. 项目收尾的目的是要确定：
- A. 影响项目交付质量的潜在风险
 - B. 项目经理在专业特长
 - C. 供未来项目使用的经验教训
 - D. 项目可行性要求
38. 在局域网络（LAN）中安装瘦客户机（thin client）体系结构的好处在于它可以：
- A. 降低单点故障的风险
 - B. 便于更新软件的版本
 - C. 在服务器停机时确保应用程序的可用性
 - D. 稳定网络宽带的要求
39. 因为 IS 审计团队资源限制，原批准的审计计划无法实施。假定已通过审计报告通报情况，最可接受的做法是哪一项？
- A. 测试控制设计的充分性。
 - B. 测试控制的运作效率。
 - C. 着重审计高风险领域。
 - D. 依靠管理层测试控制。
40. 企业目前磁带备份，每周一次全备份、每日一次增量备份的策略。最近，企业领导把磁带备份流程中增加了向磁盘备份的步骤。这种做法之所以恰当，是因为：
- A. 向磁盘备份的速度远快于向磁带备份
 - B. 数据保存在磁盘上，其可靠性高于磁带存储
 - C. 它支持非现场存储的快速合成备份
 - D. 随着技术的进步，不再需要磁带库
41. 计算机房中安装了一套火警系统，火警控制面板的最有效放置是位于：
- A. 距离 UPS 最近的机房中。
 - B. 系统管理员的办公室中。
 - C. 距服务器最近的机房中。
 - D. 大厦保安人员值班室。

42. 对一个应用系统进行审计，下面哪种情况会损害审计人员的独立性？
- A. 设计并嵌入了专门审计这个应用系统的审计模块
 - B. 为应用系统最佳实践提供咨询意见
 - C. 作为应用系统的项目组成员，但不是以后的作业使用人员
 - D. 在应用系统开发过程中，实施了具体的控制
43. 在某医院中，医务人员携带存有病人健康状况数据的手持式电脑。这些手持式电脑与可从医院数据库传输数据的 PC 同步。以下哪项措施最重要？
- A. 手持式电脑得到了妥善保护，可在发生盗窃或丢失时仍能保证数据的机密性。
 - B. 在使用后删除本地 PC 中临时文件的员工具有维护 PC 的权限。
 - C. 通过制定政策和流程来确保同步能够及时进行。
 - D. 手持式电脑的使用得到医院政策的允许。
44. 某个大型组织正在对下一年度的 IT 项目进行优先级排序。排序的依据应该：
- A. 根据项目的成本效益分析结果。
 - B. 根据组织下一年度的 IT 资源情况。
 - C. 根据项目的投资额大小。
 - D. 根据技术的先进性
45. 检查入侵监测系统(IDS)时，IS 审计师最关注的内容是：
- A. 系统没有识别出的攻击事件
 - B. 把正常通讯识别为危险事件的数量(误报)
 - C. 被系统阻断的正常通讯流
 - D. 由自动化工具生成的报告和日志
46. 以下那个指标最适合的衡量数据恢复策略：
- A. RPO
 - B. RTO
 - C. SDO
 - D. 最大中断窗口
47. 某 IS 审计师正在审查某家制造公司，并发现远程站点的主机用户通过 Telnet 经互联网连接到总部的主机上。以下哪一项是确保安全控制适当的最佳建议？
- A. 使用点对点租用线路
 - B. 使用防火墙规则，只允许该远程站点的互联网协议(IP)地址
 - C. 使用双因素身份认证
 - D. 使用 Telnet 非标准端口
48. 某 IS 审计师发现，某公司的灾难恢复计划 (DRP) 不包含托管在云端的某关键应用。管理层答复称，由云供应商负责灾难恢复 (DR) 和 DR 相关测试。IS 审计师应采取的下一步行动是

什么？

- A.制订云供应商审计计划。
- B.审查供应商合同，以确定其灾难恢复能力。
- C.审查独立审计师的云供应商报告。
- D.向云供应商索要一份 DRP 副本。

49. 某业务单位已选用新的会计应用，但并未在选择流程中提前咨询 IT 部门。主要风险是：

- A.该应用的安全控制可能不符合要求。
- B.该应用可能不符合业务用户的需求。
- C.该应用的技术可能与企业架构(EA)不一致。
- D.该应用可能给 IT 部门带来不可预见的支持问题。

50. 若要开发一个应用于整个公司的系统，最适合总体负责该项目的角色是：

- A. IS 主管
- B. 项目经理
- C. 企业高管
- D. 业务分析员

51. 原型法作为一种系统软件开发方法其主要好处是什么？

- A. 增加用户满意度的可能性
- B. 减少对测试的需求
- C. 消除对文档的需要
- D. 最大限度地减少信息系统审计师系统所需要的时间

52. 某 IS 审计师正在为公司审查启用安全套接字层 (SSL) 的网站。

以下哪一项风险最高？

- A.过期的数字证书
- B.自签名的数字证书
- C.为多个网站使用相同的数字证书
- D.使用 56 位数字证书

53. 业务连续性和灾难恢复计划中的首要目的？

- A. 保护人员的生命
- B. 保护关键信息系统资产
- C. 最小化组织的损失
- D. 提供操作的连续性

54. 一家公司很多笔记本用户，为了防止病毒在公司内网上传播，审计师建议采用哪种方式最佳：

- A. 在服务器上安装防病毒系统
- B. 禁止员工在家使用笔记本
- C. 笔记本启动的时候进行病毒扫描检测
- D. 笔记本载入新软件和数据的时候进行病毒扫描检测

55. 在采用一个中间件在局域网与大型机之间传输数据时，信息系统审计师最应该考虑的是：

- A. 不同平台之间的网络通讯流量水平。
- B. 跨平台的安全身份认证。
- C. 数据库的时间同步。
- D. 帮助恢复交易的时间戳。

56. 代码在生产发布时被错误地移除，其后绕过正常的变更程序，被转入生产环境。对执行实施后审查的 IS 审计师而言，以下哪一项最值得关注？

- A. 代码在初步实施时被遗漏。
- B. 变更未经管理层批准。
- C. 错误在实施后审查过程中被发现。
- D. 发布团队使用了相 N 的变更顺序号。

57. 哪一项评估保护公司网络中的信息安全所必需的安全级别

- A. 访问权限
- B. 数据分类
- C. 访问控制列表
- D. 商业智能

58. 事件管理的主要目标是：

- A. 测试事件发生时能否及时响应
- B. 让外部计算机安全事件影团队应来评估损害情况。
- C. 响应事件，以便业务能够连续开展
- D. 允许事件继续进行并沿着线索追溯到事件开始。

59. 当评估企业的异地存储中心时，信息系统审计师最为关注哪一项

- A. 保留期
- B. 完善的物理和环境控制
- C. 业务持续计划的测试结果
- D. 介质标签的准确性

60. 双方公司互不认识下，第一次如何建立公钥体系的真实性？

- A. 派自己的 IT 人员，去对方的公司传送对方的公钥回公司
- B. 用已事先约定的口令加密公钥，再传输予对方
- C. 传输前先以电话连络，再传输
- D. 使用自己的公钥直接传予对方，此公钥是经过认证中心认证

61. 在制定业务连续性计划（BCP）方面，以下哪一个利益方最重要？

- A. 流程所有者
- B. 应用所有者
- C. 董事会
- D. IT 管理层

62. 一个公司对员工的商务智能手机实施收回并利用
- A、为新员工更换 SIM 卡和手机号
 - B、销毁商务智能手机
 - C、安全的删除手机数据
 - D、更换智能手机内存卡
63. 对 IS 审计师而言，验证关键生产服务器是否在运行供应商发布的最新安全更新的最佳途径是以下哪一项？
- A. 确保在关键生产服务器上启用自动更新。
 - B. 在生产服务器样机上手动验证已应用修补程序。
 - C. 审查关键生产服务器的变更管理日志。
 - D. 在生产服务器上运行自动化工具，以验证安全修补程序。
64. IS 审计章程的主要目的是：
- A. 建立审计部门的组织结构。
 - B. 阐述 IS 审计职能部门的报告责任。
 - C. 详细阐述 IS 审计部门执行的审计流程和程序。
 - D. 概述 IS 审计职能部门的职责和权限。
65. 可用性最好(容错率最高)的网络结构是：
- A. 环状
 - B. 总线
 - C. 星行
 - D. 网状
66. 银行客户的密码丢失后，应该采取何种措施发放 PIN：
- A. 客户连续录入两遍
 - B. 银行工作人员通知客户一个 PIN
 - C. 通过电子邮件发送 PIN
 - D. 由银行工作人员发放一个随机产生的 PIN
67. 审查防火墙访问控制列表时， 审计师发现那种情况是有最大问题的：
- A. 用户的权限大于所在组的权限
 - B. IT 的访问权限列表中有允许和拒绝的冲突
 - C. 默认配置为放行
 - D. 默认配置为拒绝
68. 在提议的企业资源规划(ERP)系统的需求定义阶段，项目发起人要求链接采购与应付账款模块。最好执行以下哪一种测试方法？
- A. 单元测试
 - B. 集成测试
 - C. 社交性测试
 - D. 质量保证(QAT)测试

69. 在确定 IT 政策是否很好的适应业务需求时，以下哪一项是最关键的证据？
- A. 支持 IT 策略的总成本
 - B. IT 策略的例外数量
 - C. IT 策略的查询次数
 - D. 违反 IT 策略所造成的总体损失
70. 一块有缺陷的硬盘需要返回厂家进行维修，以下哪项是最好的处理方式
- A. 消磁
 - B. 覆写
 - C. 删除
 - D. 格式化
71. 某小型公司无法隔离开发流程与变更控制职能之间的职责。确保经过测试的代码与转入生产的代码完全一样的最佳途径是什么？
- A.发布管理软件
 - B.手动代码比对
 - C.生产前回归测试
 - D.管理层批准变更
72. IS 审计师最有可能在什么地方看到应用哈希函数？
- A.身份认证
 - B.标识
 - C.授权
 - D.加密
73. 镜像磁盘（mirrored disks）的使用：
- A.减少对额外存储的需求
 - B.缩短系统响应时间
 - C.消除异地备份的需求
 - D.需求定期异地备份
74. 以下哪一项是计划评审技术(PERT)相比其它方法的优点？与其它方法相比：
- A. 为计划和控制项目考虑不同的情景
 - B. 允许使用者输入程序和系统参数.
 - C. 测试系统维护加工的准确性
 - D. 估算系统项目成本.
75. 从风险管理的角度，部署庞大且复杂的 IT 基础架构，哪种方法最好：
- A. 部署前仿真模拟新的架构
 - B. 按次序阶段性的部署计划
 - C. 原型化和单阶部署
 - D. 在概念论证之后，全面迅速的部署
76. 应该实施哪一项控制措施使系统维护停机时间可降至最低？

- A. 温站
- B. 集群
- C. 每晚完整备份
- D. 负载均衡

77. 以下哪一项控制最能防止互联网嗅探器 (Internet sniffer) 进行重放攻击:

- A. 数据包过滤路由器
- B. 数字签名
- C. 正确配置的防火墙
- D. 待时间戳的数据加密

78. 某新业务需求要求变更数据库供应商。关于此项实施, IS 审计师应当主要检查以下哪个领域?

- A. 数据的完整性
- B. 切换的时间安排
- C. 用户的授权等级
- D. 数据的规范化

79. 以下哪一项是使用秘密密钥型加密的优势?

- A. 可用于数字签名
- B. 使用效率
- C. 能在用户间共享密钥
- D. 增强验证功能

80. 以下哪一项是最好地描述了 IT 战略委员会的职能?

- A. 业务部门的满意度
- B. 监控 KPI 的结果
- C. IT 战略委员会章程
- D. IT 战略委员会会议纪要

81. 固有风险评级通过对威胁或漏洞的影响及可能性评估, 威胁或漏洞发生

- A. 考虑采取内部控制措施之前
- B. 考虑内部控制措施之后
- C. 应用了补偿控制措施后
- D. 确立风险偏好之前

82. 某 IS 审计师发现, 用户偶尔地被授权作更改系统数据。这种系统访问权限提升不符合公司政策, 但对业务经营的平稳运转是有必要的。该 IS 审计师最有可能建议采取以下哪一种控制来长期解决这一问题?

- A. 重新设计与数据授权有关的控制。
- B. 实施额外的职责分离控制。
- C. 对政策进行审查, 以查明正式的例外流程是否有必要。
- D. 实施额外的日志记录控制。

83. 具有明确定义的数据分类政策和程序的最大好处是:

- A.信息资产库存更加准确。
- B.减少控制成本。
- C.减小不适当访问系统的风险。
- D.提高监管合规性。

84. IS 审计师正在审查某组织的人力资源 (HR)数据库的实施情况。IS 审计师发现:为获得高可用性而群集数据库服务器,所有默认数据库帐户已删除,并且已保留数据库审计日志并每周审查一次。为确保适当保护数据库的安全,IS 审计师还应检查哪些其他领域?

- A.限制数据库管理员访问 HR 数据。
- B.数据库日志经过加密。
- C.数据库存储的程序经过加密。
- D.数据库初始化参数适当。

85. 组织在灾难恢复计划 (DRP) 时,有多种不同的备份数据恢复方案可供选择,最需要参考的指标是:

- A. 恢复时间目标(RTO)。
- B. 恢复方案的技术成本。
- C. 可容忍的最长中断时间(MTO)。
- D. 恢复点目标(RPO)。

86. 下列哪一项是由拒绝服务攻击 (denial-of-service attacks) 导致的最大风险?

- A.未经授权访问系统
- B.败坏商誉。丢失业务
- C.泄露机密信息
- D.数据库缺乏完整性,遭到破坏

87. 安装数据泄漏防护 (DLP)软件的主要目的是控制以下哪一项?

- A.服务器上存储的保密文件的访问特权
- B.意图破坏内部网络中的重要数据
- C.哪些外部系统可以访问内部资源
- D.保密文件流出内部网络

88. 使用 EXCEL 计算项目成本时,将每个成本类别的总计录入到工作成本表时,下列哪一种方法能最好地确保数据输入的准确性?

- A. 输入后“回放”项目的详细信息
- B. 有效性检查,防止输入字符数据
- C. 核对项目的总金额
- D. 就每个成本类别检查其合理性

89. 关于能力管理的说法不正确的有:

- A. 至少每年进行审核和修改
- B. 能力计划应由用户和 IS 管理部门共同参与完成

- C. 确保 IT 服务以最优成本效益的方式满足当前和未来对容量与性能的业务需求
- D. 无需考虑新技术

90. 在准备支持电子数据仓库解决方案的业务案例时，以下哪一项在协助管理层进行决策的流程中最重要？

- A. 讨论单一解决方案。
- B. 考虑安全控制。
- C. 证明可行性。
- D. 咨询审计部门。

91. 在提交了审计报告之前，审计经理发现在审计过程总忽略了某样证据，该证据表明过程控制失败了，这可能与审计结论互相矛盾，以下哪一样风险受这一疏忽的影响最大？

- A. 固有风险 (inherent)
- B. 操作风险 (operational)
- C. 审计风险
- D. 财务风险

92. 下列哪种做法将最能确保具有永久重要性的归档电子资料，多年后还能随时查询？

- A. 购买类似旧版本软件的应用程序
- B. 定期将数据转移到采用当前的技术的系统中
- C. 定期备份归档数据
- D. 对旧硬件执行预防维护

93. 在共享的处理环境中，最大的挑战是：

- A. 分离客户数据
- B. 分离客户网络
- C. 合并结果
- D. 保持一致的标准

94. 在实施数据分类等程序时，以下哪一项最重要？

- A. 计划实施安全存储的功能
- B. 使数据所有权正式化
- C. 理解数据的分类级别
- D. 开发隐私政策

95. 对于评估业务连续性计划的有效性最好方法是审查：

- A. 预先的测试结果
- B. 异地存储和环境监控
- C. 计划并把他们作为适当的标准
- D. 应急程序和员工培训

96. 磁盘管理系统的主要功能在于：

- A. 提供有关磁盘有效利用率的数据

- B.拒绝访问磁盘驻留的数据文件
- C.见识磁盘访问，以便进行分析审查
- D.提供控制磁盘使用的方法

97. 防止服务器收到强力攻击的最有效方法是：

- A. 对服务器进行加固
- B. 连续输入三次错误锁定
- C. 更加复杂的密码
- D. 实施连续监控

98. 某企业正在开发一种新的采购系统，但进度落后于预定计划。因此，有人提议将原定的测试阶段时间缩短。项目经理向 IS 审计师询问如何降低测试时间缩短可能带来的风险。以下哪种风险缓解策略较为合适？

- A.测试并发布功能被简化的试用系统。
- B.针对最严重的功能性缺陷进行修复及重新测试。
- C.取消开发团队计划进行的测试,直接进行验收测试。
- D.使用一种测试工具自动进行缺陷跟踪。

99. 某组织正在审查其与云计算提供商之间的合同。该组织想要从合同中删除锁定条款的原因是以下哪一项？

- A.可用性
- B.可迁移性
- C.敏捷性
- D.可扩展性

100. 某 IS 审计师发现，实施了未经督导委员会批准的多个基于 IT 的项目。该 IS 审计师最需要关注什么？

- A.IT 项目资金不足。
- B.IT 项目不遵循系统开发生命周期（SDLC）流程。
- C.IT 项目未必一直得到正式的批准。
- D.IT 部门未朝着共同的目标而努力。

第三部分

1. 在网络漏洞的外部评估过程中，首先应该执行下列哪项活动？
 - A. 监控网络
 - B. 审查章程
 - C. 实施 IDS
 - D. 收集网络信息

2. 从某个供应商购买了某个新应用，并且即将实施。实施应用时，以下哪一项是关键考虑因素？
 - A. 防止在实施流程中损坏源代码
 - B. 确保已禁用供应商的默认账户和密码
 - C. 从托管中删除程序的旧副本，以免混淆
 - D. 核实供应商在履行支持和维护协议

3. 以下哪项正确描述审计风险
 - A. 员工挪用了资金
 - B. 公司被无端指控
 - C. 财务报告可能未发现重大错误
 - D. 主要人员 2 年末休假

4. 由于资源有限，某开发人员需要生产数据的完全访问权限，以支持生产用户报告的某些问题。对于控制生产中未经授权的变更，以下哪一项是好的补偿性控制？
 - A. 向开发人员提供用于编程和生产支持的单独 ID 并进行监控。
 - B. 通过启用审计轨迹来捕获开发人员在生产环境中的活动。
 - C. 在允许开发人员进行生产变更之前备份所有受到影响的记录。
 - D. 确保所有变更都经过变更管理人员批准。

5. 一名 IS 审计师正在审查某组织的物理安全措施。对于门禁卡系统,IS 审计师最应关注的是：
 - A. 将未经定制的门禁卡发放给清洁人员，他们只使用签到单，不用出示身份证明。
 - B. 门禁卡未标识组织的名称和地址，不方便归还丢失的卡。
 - C. 门禁卡的发放以及权限管理由不_的部门执行，从而导致新卡从准备到正式投入使用产生不必要的延迟。
 - D. 对卡进行编程的计算机系统只能在系统故障发生的三周后予以替换。

6. 评估 IT 治理实施的有效性时，以下哪一个因素最关键？
 - A. 确保定义了鉴证目标。
 - B. 确定利益相关方的要求和参与。
 - C. 确定相关风险及相关机会。

D.确定相关驱动因素及其适用性。

7. 质量保证（QA）人员最不应该从事哪项工作？

- A. 建立分析技术
- B. 改动程序业务功能
- C. 审查程序被修改
- D. 制定命名规范

8. 以下哪一项对战略 IT 举措决策流程最有价值？

- A.项目管理流程的成熟度
- B.监管环境
- C.过去的审计结果
- D.IT 项目组合分析

9. 一个有大量界面程序的应用，为了尽早能在前期发现界面程序的错误，应该采取哪种测试方法：

- A. 社交测试
- B. 自上而下
- C. 自下而上
- D. 逻辑路径监测

10. 以下哪一项最有助信息所有者对数据进行适当分类？

- A.了解保护数据的技术控制
- B.接受组织政策和标准知识培训
- C.使用自动化数据泄漏防护(DLP)工具
- D.了解哪些人需要访问数据

11. 针对从 PC 到 PDA 的电子邮件传输，主要应关注

- A.所传输电子邮件主题信息的日志
- B.电子邮件传输的成文政策
- C.定期传输的电子邮件记录
- D.执行传输前部门经理的审批

12. 审查数据中心的灭火系统应考虑

- A.维护措施
- B.安装手册
- C.是否能够现场更换
- D.承保范围

13. 当对某组织的台式计算机软件合规性进行审查时，安装的软件存在以下哪种情况时最需要 IS 审计师给予关注：

- A.已安装,但没有记录到 IT 部门记录中。
- B.由没有对其使用经过适当培训的用户使用。
- C.没有列于批准软件标准的文档中。

D.许可证将在 15 天后到期。

14. 审查服务台系统中类似问题时，信息系统审计师发现他们是独立问析并以不同方法解决，缺陷如下：

- A.配置管理
- B.变更管理
- C.IT 服务级别管理
- D.问题管理

15. 公司 XYZ 已将生产支持外包给在另一个国家的服务提供商 ABC。ABC 服务提供商的工作人员通过互联网远程连接到 XYZ 的生产支持网络。以下哪一项能最有效地保证在 ABC 的生产支持团队向 XYZ 提供支持时，信息传输是安全的？

- A.密钥加密
- B.动态互联网协议 (IP)地址和端口
- C.哈希函数
- D.虚拟私有网络 (VPN)通道

16. 流程所有权分配在系统开发项目中至关重要，原因是它：

- A.利于跟踪开发完成的百分比。
- B.优化用户验收测试(UAT)案例的设计成本。
- C.最大限度缩小需求与功能之间的差距。
- D.确保系统设计基于业务需求。

17. 某公司的数据保密政策要求数据全部备份并保留 15 年，然后再销毁数据。执行长期异地备份的审计工作时，信息系统审计师应当：

- A. 验证是否存在确保可读性和恢复能力的流程
- B. 审查适当安全级别的数据分类方案
- C. 确认业务中断在保险范围之内
- D. 验证业务所有者是否销毁数据之前进行复查

18. 在一项基于风险的 IS 审计中，固有风险和控制风险均已被评定为高，IS 审计师最有可能通过额外执行以下哪一项来弥补这种情况？

- A.停一走抽样。
- B.实质性测试。
- C.符合性测试。
- D.发现取样。

19. 哪种突发事件规定可使业务操作在降级模式下继续执行

- A.冗余电源
- B.网络更新配置
- C.还原过程
- D.容错硬件

20. 具有多个分支机构的某金融机构具有自动化控制措施，它要求分支机构经理审批超过一

定金额的交易。这种审计控制属于哪种类型？

- A.检测性
- B.预防性
- C.改正性
- D.指令性

21. 某企业的数据处置策略强调要对介质进行重复利用。信息系统审计应给出哪项建议？

- A. 识别标签已去除
- B. 介质退回给供应商以换取价值
- C. 介质供企业内部的其他组重复使用
- D. 任何现有的数据在处置前都已删除

22. 以下哪一种控制能最有效地减小欺诈性在线付款请求造成损失的风险？

- A.交易监测
- B.用安全套接字层 (SSL)保护 web 会话
- C.强制执行身份认证的密码复杂性
- D.在 web 表单上输入验证检查

23. 某组织正考虑作出大笔投资进行技术升级。以下哪一项是需要考虑的最重要因素？

- A.成本分析
- B.当前技术的安全风险
- C.与现有系统的兼容性
- D.风险分析

24. 企业架构(EA)举措的主要好处是：

- A.使组织的投资能够用于于最合适的技术中。
- B.确保在关键平台上实施安全控制。
- C.允许开发团队更快地响应业务要求。
- D.赋予业务单位更大的自主权，以选择符合其需求的 IT 解决方案。

25. 在对业务流程再造(BPR)工作进行审查时，以下哪一项是主要关注的问题？

- A.BPR 工作消除了一部分控制。
- B.资源不足以支持 BPR 流程。
- C.审计部门不参与 BPR 工作。
- D.BPR 工作纳入该流程领域知识有限的员工。

26. 信息系统审计师使用端口扫描软件来：

- A. 建立通讯连接
- B. 检测入侵
- C. 检测开放服务
- D. 确保所有端口在使用中

27. 决策支持系统(DSS)用于帮助高级管理人员：

- A.解决高度结构化问题。

- B.合并决策模型与预定标准的使用。
- C.根据数据分析和互动模型做出决策。
- D.仅支持结构化决策任务。

28. 一名 IS 审计师正在审查某企业的系统开发测试政策。在以下有关使用生产数据进行测试的陈述中, 此 IS 审计师会认为哪项最恰当?

- A.必须经高级 IS 和业务管理层批准使用后, 生产数据才能用于测试。
- B.只要将生产数据复制到安全的测试环境中, 就可使用。
- C.决不能使用生产数据。必须基于书面的测试案例准备所有测试数据。
- D.如果签署了保密协议,便可使用生产数据。

29. 信息系统质量保证小组负责:

- A. 监视计算机处理任务的执行情况
- B. 确保程序变更符合制定的标准
- C. 设计防止数据意外泄漏的程序
- D. 确保从系统处理收到完整的输出

30. 在一个无人的资料中心适合用什么消防器具?

- A. 喷水灭火器
- B. 七氟丙烷
- C. 二氧化碳
- D. 干管

31. 信息系统审计师查明, 在制定业务持续计划的过程中并没有进行业务影响分析(BIA).以下哪一项是这一情况可能引起的最重要的风险?

- A.没有包括关键性业务应用程序
- B.错误地定义恢复时间目标
- C.与关键绩效指标不统一
- D.未正确定义职责

32. 某 IS 审计师应要求审查针对某数据中心服务候选供应商的合同。确定签署合同后, 是否遵守合同条款的最佳途径是什么?

- A.要求供应商提供月度状况报告。
- B.与客户 IT 经理定期召开会议。
- C.对供应商进行定期审计检查。
- D.要求在合同中说明性能参数。

33. 当获得高层管理人员对灾难恢复计划的支持和制定计划所需资源的授权后, 选择起草计划的人应当具有以下哪一种能力:

- A. 具有与信息系统相关的操作系统、数据库和通讯的技术知识
- B. 具有在相同行业中的客户咨询经验
- C. 具有组织的全局观点和认识所有灾难后果的能力

D. 具有硬件和软件供货商咨询背景

34. 面向服务架构最可能

- A.危害应用程序软件安全性
- B.简化所有内部流程
- C.使合伙人之间更便利
- D.禁止与旧有系统之间集成

35. 信息系统审计师正在分析应用程序的系统日志中记录的访问采样。如果发现异常，就会启动深入调查，适合使用哪种抽样方法呢？

- A. 发现抽样
- B. 判定抽样
- C. 变量抽样
- D. 分层抽样

36. 以下哪一项是 IS 审计师报告结果的主要要求？这个报告是：

- A.根据预先定义和标准的模板进行拟定。
- B.有充分和适当的审计证据作支撑。
- C.全面涵盖企业流程。
- D.由审计管理层负责审查和批准。

37. 数据库管理系统软件包不可能提供下面哪一种访问控制功能？

- A. 在程序级的身份验证
- B. 在交易级的身份验证
- C. 用户在网络层的登录
- D. 用户对字段数的访问

38. 为确保法庭采信日志信息，最需要以下哪一项衡量标准？确保数据：

- A.具有独立的时间戳。
- B.由多个记录系统记录。
- C.经过最安全的加密算法加密。
- D.经过验证，以确保日志的完整性。

39. 在生产数据库中直接更新数据时，以下哪一项能最有效地确保问责制？

- A.之前和之后的屏幕截图
- B.经过批准的实施计划
- C.经过批准的验证计划
- D.数据文件安全性

40. 起草灾难恢复计划 (DRP)时，以下哪项陈述是正确的？

- A.停机时间成本随着恢复点目标(RPO)增加而降低。
- B.停机时间成本随时间的推移而增加。
- C.恢复成本与时间无关。
- D.恢复成本只能在短期内控制。

41. 下列那一项用于确定是否允许审计师访问应用程序？
- A. 审计范围
 - B. 最低权限
 - C. 数据密级
 - D. 访问权限
42. 对供应链管理应用程序执行业务影响分析的最佳方法是？
- A. 采纳 IT 人员对业务问题的看法
 - B. 审查组织内的策略和程序
 - C. 在关键的内部利益关系方之间开展问卷调查
 - D. 与关键利益关系人面谈
43. 应用系统开发完毕后，进行测试，以下那种情况，审计师应该最关注：
- A. 发现一些小的 Bug
 - B. 直接使用生产数据
 - C. 使用脱敏后的生产数据
 - D. 缺少相关的维护模块
44. 在开始后续跟踪审计时，审计师第一步应采取下面哪项工作？
- A. 审查上次审计的工作底稿
 - B. 与被审计单位讨论补救进展情况
 - C. 收集补救证据，以此来执行控制测试
 - D. 审查上次的审计结果和行动计划
45. RPO 低的信息系统应该采取如下哪项措施？
- A. Raid 0
 - B. 每日备份
 - C. 热站
 - D. 镜像
46. 能够最佳地提供本地服务器上的将处理的工资资料的访问控制的是：
- A. 使用软件来约束授权用户的访问
 - B. 将每次访问记入个人信息（即：作日志）
 - C. 对敏感的交易事务使用单独的密码/口令
 - D. 限制只有营业时间内才允许系统访问
47. 哪一项物理控制措施能够最有效地防止违反计算机房的安全性
- A. 刷卡
 - B. 照片 ID
 - C. 数字键盘
 - D. CCTV
48. 下列哪一项对于 IT 治理成功具有最大影响？

- A.IT 战略嵌入所有风险管理过程
 - B.IT 战略与组织愿景的统一
 - C.信息系统政策明确、简要且得以执行
 - D.CIO 是审计委员会的成员
49. IT 灾难恢复是时间目标（RTO）应基于以下哪一项：
- A.最多可容许丢失的数据
 - B.根据业务定义的系统关键性
 - C.最多可容许的停机时间
 - D.中断的根本原因
50. 下列哪一项是企业灾难冷备（互惠协议）的最大风险是？
- A.网络基础设施
 - B.硬件组件的可用性
 - C.电源连接
 - D.适当的环境控制
51. ROI 分析在 IT 决策过程中的一个好处是提供
- A.分配间接成本的基础
 - B.更换设备的成本
 - C.分配财务资源的基础
 - D.估计所有权的成本
52. 哪种控制在跨网络传输中有效检测数据意外损坏
- A.顺序检查
 - B.对称加密
 - C.奇偶校验
 - D.校验（数字）位
53. 某 IS 审计师正在评估一份针对新的云会计服务的第三方服务协议。关于会计数据的保密问题，以下哪一项考虑因素最重要？
- A.数据保留、备份和恢复
 - B.信息的退还或销毁
 - C.网络和入侵检测
 - D.修补程序管理流程
54. 某 IS 审计师在执行审计时确定，开发人员已被授予虚拟机（VM）管理控制台的管理员访问权限，以管理其自己用于软件开发和测试的服务器。对该 IS 审计师而言，以下哪一项最值得关注？
- A.开发人员具备创建或撤除服务器的能力。
 - B.开发人员已获得访问生产服务器的高级权限。
 - C.开发人员可用其应用影响生产服务器的性能。
 - D.开发人员可将未经批准的应用安装到任何服务器。

55. 以下哪一项表示与特定业务流程相关的控制风险
- A. 低估重要性限制
 - B. 职责分离不恰当
 - C. 处理的交易比较复杂
 - D. 依赖手动流程
56. 下列哪一项能够最有效地保护数据中心的信息资产不被供应商窃取
- A. 监控并限制供应商的活动
 - B. 给供应商发放访问卡
 - C. 隐藏数据设备和信息标签
 - D. 限制使用便捷式和无线设备
57. 最适于控制项目中范围蠕动
- A. 平衡 IT 资源分配
 - B. 执行用户验收测试
 - C. 评估请求更改所带来的影响
 - D. 管理项目成本
58. 信息系统审计师在实施后审查时应该最关心以下哪一项?
- A. 系统开发延迟了两个星期。
 - B. 系统没有维护计划。
 - C. 系统包含三个轻微的缺陷。
 - D. 系统超出了预算 25%。
59. 当规划实施新系统时, 公司选择并行运行的主要目的是?
- A. 确保系统满足所需的用户响应时间
 - B. 协助新员工的培训工作
 - C. 验证系统接口是否已实施
 - D. 确认系统处理能力
60. 在审计某第三方 IT 服务提供商时, 某 IS 审计师发现未按合同要求进行访问审查。该 IS 审计师应:
- A. 向 IT 管理层报告该问题。
 - B. 与服务提供商讨论该问题。
 - C. 执行风险评估。
 - D. 执行访问审查。
61. 在制定灾难恢复与应急计划时, 下面哪一种情况不是正确的考虑?
- A. 在多个站点的环境下, 应当为每一个计算机中心制定一份单独的恢复计划
 - B. 所有相对不重要的工作没有必要恢复
 - C. 在异地恢复站点恢复系统处理能力时要用到的所有资源与材料应当是可获得的
 - D. 对应急计划测试与维护应当是一个持续过程
62. 某公司正打算安装一个基于网络的入侵检测系统(IDS), 用来保护其托管的网站。该设备

应当安装在哪里？

- A.在本地网络上
- B.在防火墙之外
- C.在隔离区（DMZ）中
- D.在托管网站的服务器上

63. 以下哪一种检测型控制？

- A. 输入格式验证
- B. 进行恢复程序
- C. 密码控制
- D. Hash 总数

64. 对于移动计算,哪一种保护数据免受盗窃、竞争对手、非授权用户使用的最佳方法

- A.身份验证
- B.数字签名
- C.文件加密
- D.访问控制

65. 信息系统审计师认为 LAN 访问安全性令人满意，审计经理在复查此项工作时需要？

- A. 验证既定审计计划的步骤是否都已经执行
- B. 重新执行某些审计步骤，以验证工作质量。
- C. 评估审计师是否具有执行此工作的相应技能。
- D. 验证用户管理部门是否同意审计发现

66. 审查项目组合时，下列哪一项是管理层应考虑的最有用的指标？

- A. 该组合的当前净值
- B. 预期效益与总项目成本之比
- C. 每个项目的总成本
- D. 项目成本与总 IT 成本之比

67. 下列哪一项是制定网络服务的水平协议的（SLA）所面临的挑战？

- A.减少网络入口（entry point）数量
- B.建立设计良好的网络服务框架
- C.找到能够正确衡量的性能指标
- D.确保客户未修改网络组件

68. 一个项目经理在目标日期内不能实施所有的审计建议，信息系统审计师应该：

- A. 建议在问题被解决前暂停项目
- B. 评估未解决问题的风险
- C. 建议项目经理重新分配审计资源来解决问题
- D. 建议补偿性控制被实施

69. 设计应对潜在自然灾害的数据备份策略时，以下哪一项最有帮助？

- A.恢复点目标（RPO）

- B.需要备份的数据量
- C.数据备份技术
- D.恢复时间目标 (RTO)

70. 在进行客户关系管理系统 (CRM)应用审计时, IS 审计师发现, 相比其他时段, 用户在高峰工作时段登录系统需要很长时间。登录后, 系统的平均响应时间在可接受的范围之内。该 IS 审计师应当建议以下哪一个选项?

- A.IS 审计师不提出任何建议, 因为系统符合当前的业务需求。
- B.IT 部门应当增加网络带宽, 以提高性能。
- C.应当向用户提供详细的手册, 以正确使用系统。
- D.IS 审计师应当建议为验证服务器制定性能衡量标准。

71. 公司 XYZ 已将生产支持外包给在另一个国家的服务提供商 ABC。ABC 服务提供商的工作人员通过互联网远程连接到 XYZ 的生产支持网络。以下哪一项能够最有效地保证只有经过授权的 ABC 用户能够通过互联网连接为 XYZ 提供服务支持?

- A.单点登陆身份认证
- B.密码复杂性要求
- C.双因素身份认证
- D.互联网协议(IP)地址限制

72. 对于正确审查、批准和包含所需的项目基线修改, 以下哪一项措施最有效?

- A. 变更控制
- B. 质量控制
- C. 项目预算审查
- D. 时间影响审查

73. 某 IS 审计师正在审查某数据中心的物理安全控制, 并发现有几个领域值得关注。以下哪个领域最?

- A.紧急断电按钮盖不见了。
- B.未执行预定的灭火系统日常维护。
- C.数据中心没有安全摄像头。
- D.紧急出口门被阻塞。

74. 对于确定项目可行性而言, 以下哪一项最重要?

- A. IT 指导委员会已批准项目。
- B. 被批准的业务案例中分析了项目价值。
- C. 项目管理方法已经制定。
- D. 公司的主要竞争对手展开了一个类似项目。

75. 从外网接入内网时, 可以有效防止非授权访问的方法是:

- A. 防火墙
- B. 内容过滤服务器
- C. 入侵检测系统
- D. 代理服务器

76. 为防止病毒引入网络。下列哪一项措施最有效？

- A. 定期更新补丁
- B. 在网络入口安装防毒墙
- C. 每日开机之前扫描所有文件
- D. 在服务器上安装病毒检测程序

77. 某 IS 审计师正在为公司审查安全事故管理程序。以下哪一项是最重要的考虑因素？

- A. 电子证据监管链
- B. 系统违规通知程序
- C. 向外部机构的升级程序
- D. 丢失数据恢复程序

78. 在对用于控制物理访问的生物特征识别系统的运行，信息系统审计师最担心下列哪项？

- A. 缺乏生物特征识别培训
- B. 用户对生物特征识别的接受程度
- C. 第一类错误
- D. 第二类错误

79. 以下与用于离线打印敏感报告的打印机相关联的漏洞中，IS 审计师应认为哪项最为严重？

- A. 可以打印未经授权的报告副本
- B. 未经授权便可修改数据
- C. 操作员可阅读敏感数据
- D. 发生系统故障时输出会丢失

80. 如果 IT 支持人员和最终用户之间存在职责分离问题,则以下哪一项适合作为补偿性控制措施？

- A. 限制对计算设备的物理访问
- B. 对交易和应用程序日志进行审查
- C. 在聘用 IT 人员之前执行背景调查
- D. 在特定的一段时间无活动后，将用户会话锁定

81. 与 IS 审计客户召开审计启动会议的主要目的是：

- A. 讨论审计的范围。
- B. 确定审计资源需求。
- C. 选择审计方法。
- D. 审查审计客户应要求提供的证据。

82. 下列哪项是作业处理流程完整的最大保证？

- A. 每一笔处理资料皆由部门经理确认

- B. 处理完毕，需要签名确认
 - C. 业务异常中断时，系统会自动记录，定期检视
 - D. 业务流程已经做了明确的职能分工
83. 某信息系统审计师正在评估软件开发外包合同，应该确保？
- A. 逻辑安全控制。
 - B. 知识产权。
 - C. 业务持续运营计划。
 - D. 硬件购买计划。
84. 现场工作完成后，信息系统审计师应与被审计单位管理层会面，这主要是为了：
- A. 讨论解决方案和补救措施
 - B. 就所发现问题进行沟通理解
 - C. 收集对审计过程的反馈
 - D. 讨论是否需要额外的测试
85. 以下哪一项能够提供证明防火墙配置与公司安全策略相一致的最佳审计证据
- A. 审查规则定义库
 - B. 执行渗透测试
 - C. 分析配置更改是如何执行的
 - D. 分析日志文件
86. 对于购买新系统的可行性研究报告，应向管理部门清楚解释以下哪一方面内容？
- A. 针对关键数据处理的应用软件安全
 - B. 关键应用系统对于计算机资源的利用
 - C. 满足数据处理需求的方法
 - D. 硬件的选择标准是如何与信息系统策略计划相一致的
87. 某组织最近部署了内部开发的一个客户关系管理(CRM)应用系统。确保应用操作与设计意图一致的最佳选择是以下哪项？
- A. 用户验收测试 (UAT)
 - B. 项目风险评估
 - C. 实施后审查
 - D. 管理层审批系统
88. 某 IS 审计师在审查网络日志时发现，某员工通过调用任务计划程序启动受限的应用，在其 PC 机上运行了高级命令。这是哪类攻击的示例？
- A. 竞态条件
 - B. 特权升级
 - C. 缓冲溢出
 - D. 模拟

89. 下列哪一项最可能包括在实施后审查中？

- A. 测试结果
- B. 当前测试数据
- C. 开发方法
- D. 实际运行的处理（live processing）结果

90. 在什么样的环境下进行重点测试（stress testing）最为理想？

- A 有生产负荷的测试环境
- B 有测试数据的生产环境
- C 有生产负荷的生产环境
- D 有测试数据的测试环境

91. 组织把一个重要的业务系统迁移到服务器-客户机架构上，最大的风险是：

- A. 组织的开发维护人员没有服务器-客户机的开发维护经验
- B. 某些项目变更未正式批准
- C. 服务器-客户机架构风险
- D. 没有迁移失败的回退方案

92. 企业里有个混合访问点不能升级其安全强度，而新的访问点具有高级无线安全特性。IS 审计师建议用新的访问点替换老的混合访问点，下面哪一个支持 IS 审计师的建议的理由最为充分？

- A. 新的访问点易于管理
- B. 新的访问点具有更高的安全强度
- C. 老的访问点性能太差
- D. 整个企业网络的安全强度，就是其最为薄弱之处的安全强度

93. 系统采用帐单每周自动传输到企业帐户总帐，经检查发现缺少一周的帐单，应检查

- A. 模块访问权限
- B. 批处理控制
- C. 变更
- D. 年度对帐

94. 某经理希望保证连接大厅办公室入口的安全，以下哪一项是最安全的物理访问控制？

- A. 刷卡和警卫
- B. 门锁和 CCTV
- C. 射频识别
- D. 挑战应答设备

95. 单点登入（SSO）的主要风险：

- A. 单一系统故障会影响所有系统
- B. 不能有效的留下访问轨迹
- C. 一次登入所有系统
- D. 系统整合困难

96. 业务流程再造(BPR)过程中,IT 可协助

- A.职责分离
- B.总拥有成本
- C.集中于增值任务
- D.使任务流程化

97. 某 IS 审计师正在审查某组织, 以确保与数据违规情形有关的证据得到保留。对该 IS 审计师而言, 以下哪一项最值得关注?

- A.最终用户不知晓事故报告程序。
- B.日志服务器不在单独的网络上。
- C.未坚持进行备份。
- D.无监管链政策。

98. 以下哪一项控制措施能够最有效地确保董事会收到有关 IT 的足够信息?

- A. CIO 应要求向董事会个别成员作简短陈述。
- B. CIO 及时报告绩效和纠正措施。
- C. 董事会成员熟悉 IT 并就 IT 问题咨询 CIO。
- D. 董事会、CIO 及技术委员会之间召开会议。

99. 下面哪一项最可能包括在实施后审查中?

- A. 项目测试数据集
- B. 项目结果
- C. 实时处理结果
- D. 项目实施方法

100. 某员工执行计算机操作, 并在必要时对程序加以修改, 信息系统审计师应建议什么?

- A. 应额外增加员工, 以便进行职责分离
- B. 应建立一套程序, 以确保对计算机程序所作的更改得以识别和批准
- C. 自动记录对开发库程序所作的修改
- D. 访问控制应禁止操作人员对程序加以修改